

醫療機構導入生成式 AI 的資料治理與落地路徑

同意書、去識別化與衛福部三大中心治理藍圖

整理：謝慕揚 MD, PhD, FESC

2026

本簡報為個人整理之合規方向參考，非法律意見；施行前請會同醫院法務 / 個資保護窗口與 IRB 確認。

本日議程

1. **問題意識**：推 AI 卡在資安 / 個資
2. **法律地基**：個資法第 6 條與同意書的定位
3. **衛福部三大中心**治理藍圖（資安解法在此）
4. **雙軌治理 SOP**：內部用途 vs 外部 / 研究
5. **病人同意書**要件與衛福部生成式 AI 指引
6. **行動建議**與法規時程

核心結論

同意書「合法、值得做，但不是萬靈丹」

真正讓三大用途跑得動的主角是：

去識別化 + 院內部署 AI + 既有特定目的 / 法定義務

先把資料的「進 AI 管道」鎖在院內，法律問題會少一大半。

一、法律地基

個資法第 6 條與同意書

特種個資與「書面同意」三陷阱

《個資法》第 6 條：病歷 / 醫療 / 健康檢查屬**特種個資**，原則禁止，6 款例外之一為「**當事人書面同意**」→ 同意書站得住，但：

陷阱	說明
概括同意無效	逾越特定目的必要範圍、違反當事人意願即不算數；須逐項列明用途、AI 對象、資料範圍、保存、撤回
不免除其他義務	醫療法第 72 條（不得無故洩漏）；送外部 AI = 委外，廠商出事 你照樣負責
真正瓶頸 = 送進哪種 AI	公有雲外國 LLM = 跨境 + 第三方；電子病歷上雲以 境內為原則 ，境外須報主管機關審核

你的三個用途，兩個其實不太需要同意

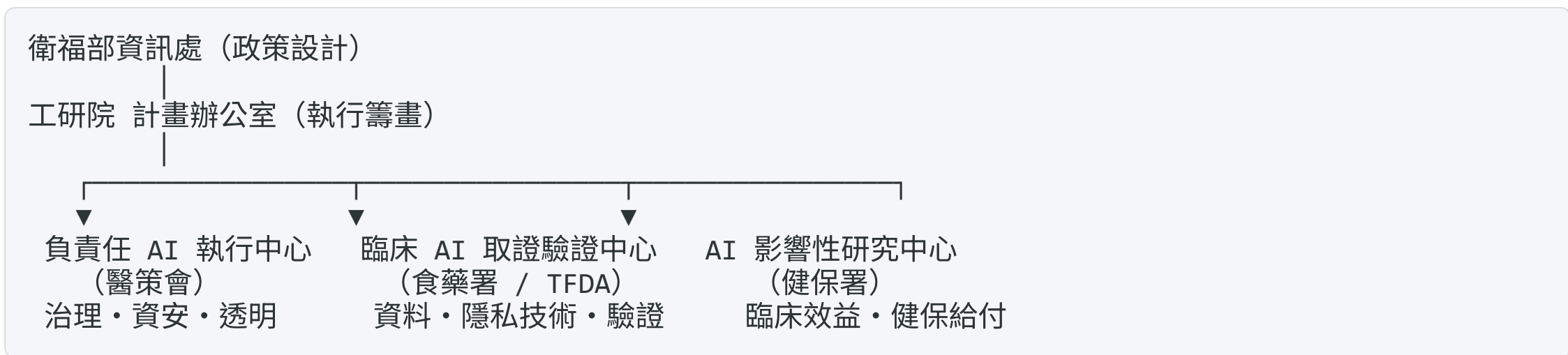
用途	較合適的法律基礎	需另簽同意？
1. 加速藥物副作用（ADR）審核	通報屬 法定義務 （藥事法 / 藥害救濟法）	多半不需
2. 健保醫材 / 藥物申請	健保特約之法定 / 契約義務；AI 協助撰寫 = 內部工具	不需
3. 醫療品質管理 / 病人安全	本身即個資特定目的 ，屬原始目的內部利用	不需（最穩）

與其押寶同意書，不如把焦點放在「**讓資料用安全的管道進 AI**」。

二、衛福部三大中心

醫院導入 AI 的治理藍圖

三大類型智慧醫療中心：執行架構



依循 **WHO** AI 倫理指引；對標美國 **ONC HTI-1 規則**與 **FAVES** 標準 (Fair, Appropriate, Valid, Effective, Safe) 。

(資料來源：衛福部資訊處〈三大類型智慧醫療中心技術手冊〉113/07)

中心 1：負責任 AI 執行中心 — 對「資安疑慮」的直接解答

- **六大原則**：保護自主權、促進福祉與安全、透明可解釋、責任當責、包容公平、永續性
- **資安 / 隱私 / 去識別化**：依 **HIPAA + GDPR** 移除可識別個資；規範儲存地點 / 期限 / 權限、加密、嚴格存取控制、定期備份與稽核、外洩回報；防火牆 + **IDS/IPS**、網路分割、自動弱點掃描
- **透明揭露 8 欄 (Model Facts Label)**：目的、輸出、超範疇警告、開發與輸入特徵、公平性、外部驗證、量化效能、持續更新
- **可解釋性 (XAI)**：SHAP、LIME、Saliency、PDP、ALE、Feature Importance、Counterfactual
- **生命週期監測**：偵測 data / model drift，低於閾值觸發再訓練 / 下架（閉環）

中心 2：取證驗證中心 — 「用 AI 又不洩資料」的技術解法

- 以 FHIR 為基礎的標準化電子病歷資料庫 (HL7 FHIR , 資料拆成可組合的 Resource) , 透過 ETL 轉換 , 橋接 OMOP CDM / cBioPortal / XNAT / i2b2
- 隱私保留核心 = 聯邦學習 (Federated Learning)
 - 平台 : FLOWER / TFF / PySyft ; 演算法 : FedAvg 、 FedProx 、 SplitNN
 - 原始資料不出院即可跨院訓練 / 驗證 ← 資安關鍵招
- CIRB (中央 IRB) 統一審查、去識別化標準化整合資料庫、送 TFDA 認證

院內地端部署 + 去識別化 + 聯邦學習 = 手冊背書的資安路線。

中心 3：影響性研究中心 — 證明價值、爭取健保給付

- **TFDA 認證只證明準確，真實臨床效益要靠前瞻 RCT**
 - 反例：Lång 2023 《Lancet Oncol》乳房攝影 AI cluster RCT
 - 正例：**Viz LVO** (中風) → 取得美國 **CMS NTAP** 每案 1,040 美元給付
- **驗證方法學**：CBAT、**DiD (雙重差分)**、**ITS (中斷時間序列)**、Cluster RCT、**Stepped-Wedge 階梯楔形**
- **衛生經濟**：QALY、**ICER**、成本效益平面；對照支付意願閾值 (人均 GDP 1–3 倍)
→ 健保署 HTA 給付決策

三、雙軌治理 SOP

雙軌治理：內部用途 vs 外部 / 研究

	A 軌：三個用途（內部）	B 軌：外部 AI / 研究二次利用
法律基礎	原始特定目的 / 法定義務	同意 + IRB
資料處理	去識別化 + 院內地端部署 AI	去識別化 + 委外契約 / 境內
同意書	透明度補強（非唯一依據）	必要，含退出機制
監督	品質監測、生命週期	CIRB、聯邦學習、外部驗證

先走 A 軌把三個用途落地；要外送或要發表再進 B 軌。

可採用的既有做法（務實菜單）

1. 去識別化優先（去識別到不再是個資 → 連同意都不用）
2. 院內地端部署 / 私有雲 AI（最大解鎖鍵，繞過委外 + 跨境）
3. 委外契約 + 資安（DPA 模式）：境內儲存、廠商 = 受託機構
4. IRB / 倫理委員會：研究性質；最小風險去識別化可申請同意豁免
5. 直接遵循衛福部生成式 AI 指引當院內 SOP
6. 留意 SaMD 紅線：AI 給診斷 / 治療建議 → 可能需食藥署查驗登記

四、病人同意書

與衛福部生成式 AI 指引

病人同意書：必備要件

- **逐項勾選用途**：ADR 審核 / 健保申請 / 品質管理（未勾選不在範圍）
- **資料範圍最小化 + 去識別化**先行
- **處理場所三擇一**：院內地端 / 委外（境內、簽約、不轉用） / 境外（須報審核）
- **病人權利**：拒絕不影響就醫、**隨時撤回 / 退出**、查詢更正
- **目的拘束 + 保存期限**，逾期刪除或不可逆去識別化
- **醫師最終把關**：AI 僅供參考，責任仍由醫師負

範本已備（含填空欄與法源對照）；定稿請過**法務 / 個資窗口與 IRB**。

衛福部《醫療機構應用生成式 AI 指引》四原則

1. **隱私優先 / 委外規範**：委外須以合約明定，處理可辨識病人資料不得外洩或轉作他用
2. **告知與揭露**：AI 錄音 / 錄影須事先告知、可拒絕；AI 與民眾對話須主動揭露、提醒勿全信
3. **臨床安全監測**：建監測機制防 AI 幻覺 / 錯誤資訊（捏造文獻、錯引指引）
4. **醫師最終把關 / 防偏誤**：醫師為最終責任者；避免模型系統性偏誤

 官方入口：aicenter.mohw.gov.tw（智慧醫療三大中心治理規範）

法規時程：方向是「治理 + 可退出」

- 2022/08 111 憲判 13 號（健保資料庫案）
 - 須給民眾「事後退出」機制與獨立監督
- 2025/12/02 立院三讀《全民健康保險資料管理條例》
 - 退出權；違法最高罰 1,000 萬
 - 配套設「個人資料保護委員會」

即使有法源，法院仍要求**事後控制（退出權）** + 治理。
從第一天就把「可退出 + 治理紀錄」設計進去。

行動建議（給院內委員會）

1. **成立 / 借用智慧醫療（AI 治理）委員會**，設第一窗口與透明性網頁
2. **三個用途先走 A 軌**：原始目的 + 去識別化 + 院內地端 AI
3. **導入聯邦學習 / 去識別化**作為資安主線
4. **同意書**由法務 / 個資窗口共同擬稿、過 IRB；內建退出權
5. **建立生命週期監測**：drift 偵測、效能閾值、再訓練機制
6. 為新法（健保資料管理條例、個資會）**預作合規設計**

謝謝聆聽

Q & A

整理：謝慕揚 MD, PhD, FESC

一句話：同意書是配角，主角是「去識別化 + 院內部署 AI + 既有特定目的」。

本簡報非法律意見；實際施行前請會同醫院法務 / 個資保護窗口與 IRB 確認。